

Assignment 3 - Business Resumption Planning through IR, DR, and BC Lenses

Melvin Viado: 100899671

Tim Loudon: 100791672

Daniel Lindo: 100788148

Emmanuel Ajayi: 101035407

Cybersecurity, Durham College

MGMT 1212: Incident Handling and Response

Sadeq Bani Melhem

April 12, 2026

Part 1: Foundations of Contingency Planning.....	4
1.1 CP Timeline Breakdown.....	4
Incident Response (IR).....	4
Disaster Recovery (DR).....	4
Business Continuity (BC).....	4
1.2 Business Resumption (BR) Plan Overview.....	6
DR and BC Distinction.....	6
Part 2: Scenario Walkthroughs.....	7
Scenario 1: IR-Only Response.....	7
Business Domain.....	7
Healthcare (Mid-sized Hospital — General Regional Hospital).....	7
Scenario Description.....	7
Detection.....	7
Containment.....	7
Eradication & Recovery.....	7
Escalation Rationale (Why DR was NOT Required).....	8
Post Incident Measures.....	8
IR Team Roles.....	8
Scenario 2: Escalation from IR to DR + DR Plan Addendum.....	9
Scenario Description.....	9
IR Phase.....	9
DR Phase.....	9
DR Plan Addendum.....	10
Metrics.....	11
Scenario 3: Full Lifecycle – IR → DR → BC + BC Plan Addendum.....	12
Walkthrough.....	12
Scenario Overview.....	12
IR and DR Actions Taken.....	12
DR Limitations.....	13
Coordination with Business and Operations Teams.....	13
Upper Management, IT and Dispatch Leadership.....	13
Operations Teams (Patrol supervisors, Detectives, Evidence Maintenance)..	13
Administrative and Business.....	13
Command.....	13
Restoration Phases.....	14
Phase 1.....	14
Phase 2.....	14
Phase 3.....	14

Phase 4.....	14
Notifications.....	14
Internal Notification.....	14
External Notification.....	15
Recovery Site Selection.....	15
BC Plan Addendum & Metrics.....	15
Trigger for BC relocation.....	15
Preparation Before Relocation.....	15
Relocation to Alternate Site.....	15
Return to Primary Site.....	16
Metrics - Effects on Site Selection, Timing and Risk Tolerance.....	16
RTO.....	16
RPO.....	16
MTD.....	16
WRT.....	16
Site Selection, Timing, and Risk Tolerance.....	16
Part 3: Conclusion & Reflection.....	17
IR, DR, and BC Interdependency in Real-World Disruptions.....	17
How Recovery Metrics Shape Contingency Strategy.....	17
Priority in Developing a BR Plan.....	17
Effectiveness of Continuous Improvement and Testing for BC Readiness.....	18
References.....	20

Part 1: Foundations of Contingency Planning

1.1 CP Timeline Breakdown

Incident Response (IR)

The NIST 800-61 incident response lifecycle provides a structured approach to handling cybersecurity incidents through four key phases: preparation; detection and analysis; containment, eradication, and recovery; and post-incident activity. In the preparation phase, organizations establish policies, procedures, and teams, define incident criteria, assign responsibilities, and coordinate with external partners such as law enforcement and forensics experts, while also conducting training and tabletop exercises. The detection and analysis phase focuses on identifying and assessing incidents using tools like SIEM systems, intrusion detection systems, and antivirus software to determine their nature, scope, and impact. The containment, eradication, and recovery phase aims to mitigate damage by isolating affected systems, removing threats and vulnerabilities, and restoring systems to normal operations securely. Finally, the post-incident phase emphasizes reviewing and documenting the incident to identify lessons learned and strengthen future response strategies.

Disaster Recovery (DR)

IT operations at the primary site are restored after a disaster may involve incremental backups, hot site models, and cloud sync virtualization that satisfy disaster recovery requirements, minimal downtime, and data loss. Incremental backups capture changes from the last backup which can be conducted more frequently and provides a faster restoration compared to slower full backups. Hot site models mirror production environments that provide an immediate backup system without noticeable downtime when the primary system fails. Cloud sync virtualization mirrors workloads to a cloud site that provides further backup systems while the primary hardware is being repaired or rebuilt, ensuring business continuity in the environment.

Business Continuity (BC)

Resuming critical business functions at an alternate site starts with declaring the disaster and activating the plan. Personnel and assets are relocated in phases, where critical functions are prioritized first such as moving workstations, network connections, and transport. Distance between sites, power reliability, and available space is considered for physical and IT security. Mobile recovery options such as leasing trailer mobile sites are

deployed at safe locations under the service level agreement terms if traditional sites are unavailable. Operations are resumed by restoring systems, testing connections, and launching business processes. The responsibilities of IT at this stage are divided for tech setup and communications for stakeholder updates. The last step is to stabilize and return by monitoring performance and returning to the primary site once it is safe, which is declared by the project manager. Traditional relocation can fail due to overwhelming disasters such as flooding or blackouts, in which cloud-based strategies must be forced as a decentralized continuity plan.

1.2 Business Resumption (BR) Plan Overview

DR and BC Distinction

Disaster recovery prioritizes recovery time objectives and recovery point objectives, focusing more on IT and handles the restoration of systems, data, and infrastructure through backups, failover sites, and server rebuilding after the disaster has happened. Business continuity involves all departments to ensure that business functions can continue during and after incidents have occurred through risk mitigation, alternative work environments, and resource allocation. Aligning disaster recovery and business continuity with maximum tolerable downtime and work recovery time is important because it allows the recovery plans to prevent irreversible harm and match with the business risk tolerance. An aligned DR and BC ensures that systems are reliable and ensures that total downtime does not exceed the limit. BC can tolerate more downtime because it involves sustaining essential operations while DR involves quickly restoring critical IT systems that other business processes are dependent on.

Part 2: Scenario Walkthroughs

Scenario 1: IR-Only Response

Business Domain

Healthcare (Mid-sized Hospital — General Regional Hospital)

Scenario Description

At 10:22 AM on a Wednesday, a nurse at General Regional Hospital observes that the operation is very slow on her computer and a patient records app is displaying multiple authentication errors. She informs the IT Help Desk about it. A Help Desk tech remotely accesses her computer and sees an unknown process using a lot of CPU. The technician then refers it to the Security team, who start the formal IR process.

Detection

The SOC analyst adds the compromised device to the SIEM dashboard (Splunk) and connects the suspicious process with the malware signature database. A credential harvesting trojan - a keylogger variant - is recognized as the malicious process and its delivery was traced to a malicious email attachment which the user had opened that morning. The malware had been running undetected in the system for about 40 minutes. No lateral movement or data exfiltration to external IPs are observed in the network logs so far.

Containment

According to NIST 800-61 guidelines (Cichonski et al. 2012), the IR team promptly initiates containment. Disabling the defective workstation's switch port effectively isolates it from the network. The analyst relies on CrowdStrike Falcon, an EDR tool to kill the malicious process and block the running of any additional payloads. For safeguarding purposes, the nurse's Active Directory credentials are turned off without delay and have been reset. A thorough examination of authentication logs validates the fact that no successful lateral movement to other hosts or to the Electronic Health Record (EHR) system has occurred.

Eradication & Recovery

The IR team wiped the infected workstation and installed a fresh, hospital-approved image on it. The nurse's account got unlocked, and a new password was set along with mandatory MFA. The harmful email was removed from the mail server & blocked at the gateway. Further investigating the email system revealed that two more staff members received the identical phishing email. Their workstations were checked for viruses and found to be clean as no malicious scripts were executed on the machines.

Escalation Rationale (Why DR was NOT Required)

The incident was completely managed during the IR phase as: the malware was confined to a single endpoint; none of the major clinical systems (EHR, lab systems, imaging) were compromised; there was no indication of a data breach or data loss; and the infected computer was back up and running within 2 hours. The incident did not meet any criteria for a DR activation - no critical systems were shut down and the event did not disrupt operations.

Post Incident Measures

Incident report created by the IR Lead 24 hrs after the incident and entered it in the ticketing system(ServiceNow) The Privacy Officer was notified to determine whether a report under PHIPA (Personal Health Information Protection Act) was necessary - they decided it was not required since no data access was confirmed.

Phishing awareness communication sent to the whole staff by the end of day. IOCs (Indicators of Compromise) from the malware sample were shared with the hospital's threat intelligence feed.

IR Team Roles

Role	Responsibility in This Incident
IR Lead	Coordinated response, authorized containment actions, filed post-incident report
SOC Analyst	Detected alert in SIEM, performed initial triage and malware identification
EDR/Endpoint Specialist	Used CrowdStrike to terminate process and scan environment
Help Desk Technician	First point of contact; escalated to SOC upon identifying suspicious process
Privacy Officer	Assessed regulatory notification obligations under PHIPA

Scenario 2: Escalation from IR to DR + DR Plan Addendum

Scenario Description

While undergoing normal business operations at a large e-commerce organization, customers and employees reported increasingly long wait times and lag when trying to access network resources. When technicians went to perform an inspection of the organization's on-site main server, they noted failing hardware shortly before the server died.

IR Phase

The IR phase was triggered as soon as technicians discovered the failing server hardware and preparations got underway to repair the server. The situation escalated however when efforts to contain the incident failed and the server shut down completely due to the failing hardware components. From here, plans changed from physical maintenance to emergency repair.

DR Phase

As soon as the situation was recognized to be a disaster, the IR team put the organization's disaster recovery plan into place for situations regarding catastrophic failure of a server. Due to the functionality of a live server being mission critical in order for business operations to resume, the IR team activated the organization's hot site server in order to quickly resume operations.

When the hot site was activated, repair teams were brought in under the supervision of one of the organization's senior system administrators to bring the main server back online and synchronize data with the hot site as quickly as possible to avoid the excess expense of using a hot site long-term.

DR Plan Addendum

Disaster Type	Technical event
Trigger	Main server for the organization suddenly went down after reports of lag and slow response times
Team Lead	Senior system administrators communicating with the CIO and CISO
Notification Method	Alert from technicians originally going to repair the server notifying that it had gone down completely
Response Time	Instantaneous, company resources were switched to the hot site within minutes
Actions during disaster	● System administrators were notified of the server going down ● Decision was made to switch to the organization's hot site ● Repairs were made to the main server ● Main server was synchronized with the hot site and put back online
Actions taken after disaster	● Hot site was taken offline ● IR team reviewed what happened and why to make modifications to the IR plan ● Decisions were made to do more frequent inspections of servers to identify faulty hardware to mitigate further incidents

Metrics

RTO	Between 30 minutes and an hour and a half for the hot site to come online and ensure it is properly configured
RPO	Due to the existence of a hot site, no more than a few minutes
MTD	Around 3-5 hours to bring the main server back online and stop the use of the hot site
WRT	No more than 30 minutes to verify customers and employees can access server information again

Scenario 3: Full Lifecycle – IR → DR → BC + BC Plan Addendum

Walkthrough

Scenario Overview

In this scenario we are covering a police department that has suffered a cyber attack that has left most of its systems in a dire state. A devastating ransomware attack was deployed by a hacker group which left the police department with the majority of their drives, files, and even criminal databases vulnerable and encrypted. Other services like their dispatch hotline are also down and inaccessible. Electricity and utilities are unaffected, but most of the networking equipment and data on site are compromised.

IR and DR Actions Taken

The IR team immediately took note of the ransomware incident, which occurred in the early morning at 6am. Multiple systems became inaccessible, and private lines were used to reach out to other departments of IT, along with police within and outside of the building during the incident. All systems that were found to be affected by the ransomware were immediately taken offline, from a secure server compromised accounts were disabled, and malicious IPs found during the incident were blocked. Many systems as a result of this were also air gapped from the network. Multiple disk images, and SIEM reports were made and backed up to a remote off-site location and locally on media disconnected from the network. Critical operations were also restored to ensure police could be dispatched to emergencies in the town. Manual dispatching was utilized involving radios and paper logs, some work was differed to other police departments in the area, and the 911 phone line was securely restored.

When it comes to DR (disaster recovery), this is where the challenges mount higher. With the sheer complexity of the systems a police department has, and the sheer number of affected systems, before the mobile site was deployed simpler less efficient methods were utilized to regain basic functionality. Some VMs and servers were rebuilt with clean images. Unfortunately the local criminal database was compromised, however there was an off-site backup that could be referenced, however bringing it online for the current site was too high of a risk. Far too many systems aside from those responsible for every-day police activity were also infected with malware, making the site unclean and risky to utilize for work

DR Limitations

When it comes to limitations, most stem from the damage of the combination of the attack being ransomware, and other forms of malware were also used in the attack to infect other systems that make them unusable or compromised. A mobile site was deployed to restore core functions. A live line for users to contact for police dispatch (911). Police Department services, crime and identity database recovery and utilization, along with servers that officers could access when attending to emergencies in the field. The mobile site was necessary to keep operations running, as a police department cannot handle multiple hours of downtime. The mobile site also provided a clean, unaffected place to recover systems, check backups, and maintain critical services for civilians to contact police.

Coordination with Business and Operations Teams

When it comes to coordination, multiple teams would need to work together within the department to regain systems and establish clean services. This will be broken down in order.

Upper Management, IT and Dispatch Leadership

These teams would immediately have to coordinate tasks that must be delegated and, and what systems need to be brought back up immediately. This also trickles down to collecting necessary data and what each department should focus on restoring or wiping.

Operations Teams (Patrol supervisors, Detectives, Evidence Maintenance)

These teams would focus on providing impact assessments and on identifying the systems that must be restored without delay.

Administrative and Business

HR, Finance, IT and Legal departments are required to coordinate so that communication with municipal leadership is established, so that the current disastrous situation can be resolved and accounted for, especially with reporting the method of attack that compromised their police department.

Command

Efficient leaders and disaster recovery plans would need to work in tandem to ensure that forensics can gather sufficient evidence, the situation is contained as much as possible, restoration occurs in a timely manner, and that the mobile site is up and running to keep police operations running smoothly to meet the needs of the general public, while

coordinating with other departments in the area to notify them of the cyber attack, methods used, and other duties to ensure the general public can be serviced.

Restoration Phases

This will be broken down into four phases.

Phase 1

Critical services will be restored, such as 911 dispatch, radio, patrol dispatching, and connectivity and transfer of services to the mobile site.

Phase 2

Core systems must be rebuilt or replaced. Backups must also be utilized to restore systems and ensure that critical data has been maintained.

Phase 3

Support systems must also be restored, such as email, administrative applications, reporting tools, and non-critical services. Majority will be run from the mobile site until equipment within the building is replaced and hardened from future security breaches.

Phase 4

Validation and reintegration will occur from this point. Services will be transferred from the mobile site, and equipment within the police department building will be hardened and running. Databases will be up, along with dispatch services and patrol dispatch services. Mobile site use will no longer be needed, as the building and the equipment therein is new, secure, and ready to use for long term deployment.

Notifications

Notification can be broken down into two cases. Notification on the internal staff, and notification of external staff and municipal departments, and general public.

Internal Notification

Multiple levels of staff would be notified of this incident or witnessed it. Patrol Supervisors, Command Staff, and Dispatch would be the first to be notified via a secure line or secure out-of-band radio. Following this, all officers would be notified by a secure SMS alert, along with updates on the ongoing situation, and what will be done to mitigate it. Finally, municipal leadership and IT will be notified via encrypted communications, addressing the situation and disaster recovery steps.

External Notification

External notification would include mandatory reporting to provincial cybersecurity centers and other police departments. Partner agencies would also be notified to delegate tasks that the department is unable to address at the time of the incident. Vendors would be notified along with the mobile site provider, and finally the general public would also be notified of the incident, however technical details would be limited.

Recovery Site Selection

Mobile

BC Plan Addendum & Metrics

Trigger for BC relocation

The trigger in this scenario is simple, RTO for the critical systems is not a wide timeframe. Many systems in a police department are critical by nature, as must be back up and running within 1-5 hours. 911 dispatch had to be back up within 2 hours or less, so the mobile site had to be deployed as the environment was unaffected. Other reasons also include that the criminal databases are also critical assets, along with the fact of most systems within the building being infected with either invasive malware or ransomware.

Preparation Before Relocation

- Assessment of the ransomware and malware impact of devices and the network core systems
- Switching to manual dispatching of officers where feasible
- Preservation of forensic evidence, and isolation of infected systems from clean ones
- Notification of leadership to initiate deployment of the mobile site, and movement of staff and resources

Relocation to Alternate Site

- Deployment of the mobile site and establishment of a secure network and radio
- Restoration of 911 dispatch, essential systems, and clean backups in the mobile site environment
- Maintain coordination with the Incident Response team addressing the compromised facility
- Transition officers from manual dispatching to the clean system in the mobile site

Return to Primary Site

- Confirmation of the full sanitization of the primary facility, network, core systems, forensics, and rebuilt devices, servers and databases
- Switch services from the mobile site to the main facility without cutting operations
- Migrate the restored systems from the mobile site back to the main facility while ensuring integrity checks
- Decommission of the mobile site and conduct a post incident review, along with updating procedures

Metrics - Effects on Site Selection, Timing and Risk Tolerance

RTO

When it comes to the recovery time objective, critical 911 systems must be online within 2 hours to ensure response time to community emergencies.

RPO

The recovery point objective is practically instant, at 5 minutes. Backups must be as close as possible to current events, in relation to call and dispatch data. Hence the necessity of a mobile site. A cold or warm site would take far too long.

MTD

The maximum tolerable downtime is 1 hour. If this is exceeded, public safety operations would be at serious risk.

WRT

The work recovery time could take 6 hours or longer, as data would need to be synchronised to restore normal operations of the police department.

Site Selection, Timing, and Risk Tolerance

The site selection requires a mobile site to smoothly transition from the compromised police department to the mobile site that has servers and dispatching equipment ready to handle the influx of calls that will flood the system after downtime from the cyber attack. The police department cannot handle multiple hours of downtime without the safety of the public reaching critical levels. The risk tolerance as a result is low, as all services within the department would need to be functional so that public emergencies can be tended to. Simply having 1 hour of downtime could be catastrophic.

Part 3: Conclusion & Reflection

IR, DR, and BC Interdependency in Real-World Disruptions

IR, DR, and BC are interdependent in real-world disruptions because an incident will navigate through all three. Firstly, an IR contains and investigates the incident which identifies what happened, the scope of the damage, and if attackers or danger is still present. DR restores the affected systems once the cause of the incident or danger is removed. It is important to restore systems after removing the cause because you can risk reinfection or repeating the outage. BC keeps the organization operating while system restoration continues to happen and depends on both IR and DR. BC uses alternative work environments and resource prioritization to continue services while IR and DR do their jobs. Recovery speed and recovery decisions are important to safely keep the business running and you cannot recover well if one of IR, DR, or BC fails.

How Recovery Metrics Shape Contingency Strategy

By establishing acceptable disruption, you can use recovery metrics to help shape the contingency strategy. RTO can help plan which systems will receive the fastest recovery paths and RPO will plan the frequency of backups and design of replication. WRT helps plan testing and validation of the contingency plan keeping in mind that a system can be online before it is truly operational. MTD helps plan the entire recovery design to make sure that the total recovery time does not exceed this tolerance. These recovery metrics help you choose your recovery site selection and how much budget you allocate to backups and redundancy. Tighter recovery metrics will mean you are spending more on a resilient infrastructure while loose recovery metrics will allow for slower and cheaper recovery options.

Priority in Developing a BR Plan

In our scenario, the first thing to prioritize in developing a BR plan is the safety for patients and the continuity of healthcare. Therefore, we must identify critical clinical functions that would immediately threaten the health of our patients and place it at the top of our priority list. Time-critical clinical services such as surgery and medication administration come first because any delays can directly harm the patients. Following that, other critical clinical systems and healthcare workflows involving patient monitoring, access systems and staff communication should be prioritized next. Lastly, aligning the healthcare continuity plan with compliance and jurisdictional regulations should also be prioritized for

the continuity of healthcare. Therefore, the plan is to recover immediate patient-safety, then supporting systems, then administrative services.

Effectiveness of Continuous Improvement and Testing for BC Readiness

By performing regular exercises to expose gaps, confirming realistic recovery steps, and ensuring role familiarity when a crisis happens, you can confirm that your business continuity plan is effective and working under real conditions. Testing is used to confirm that the plan can meet recovery targets, that backups work, and whether staff knows what to do in the event of an incident. It can also reveal the communication dependencies between teams, systems, and vendors that can be easily overlooked. Continuous improvement is important in the BC because the environment of the organization can change over time and plans can quickly become outdated. Improvement also turns plan testing into feedback for better procedures and training. For example, a business continuity team performs a drill to restore a system but are unable to communicate with other departments fast enough to restore the system. Therefore, the plan is not ready to be effectively used and improvements on communication and role clarification should be made to minimize response time and increase coordination where possible.

References

Burgett, A. (2026, February 26). *Practical incident response guidance from NIST SP 800-61*. ArmorPoint.

<https://armorpoint.com/2024/05/08/a-step-by-step-guide-to-incident-response-practical-guidance-from-nist-sp-800-61/>

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012, August 6). *Computer Security Incident Handling Guide*. CSRC. <https://csrc.nist.gov/pubs/sp/800/61/r2/final>

Goh, M. H. (2020, December 28). *Dr strategy: Types of alternate sites*. Crisis Management.

<https://blog.bcm-institute.org/it-disaster-recovery/dr-strategy-types-of-alternate-sites>

Mosher, R. (2025, July 23). *Incident response vs disaster recovery vs business continuity*. HBS.

<https://www.hbs.net/blog/incident-response-vs-disaster-recovery-vs-business-continuity>

RAID and Cloud Storage Integration Guide. RAIDON. (n.d.).

https://www.raidon.com.tw/RAIDON2016/knowledge_detail.php?id=19

Rivas, K. (2025, January 14). *Disaster recovery 101: Hot vs. Warm vs. cold dr sites*. Backblaze Blog | Cloud Storage & Cloud Backup.

<https://www.backblaze.com/blog/disaster-recovery-101-hot-vs-warm-vs-cold-dr-sites/>

Shulmistra, D. (2025, November 13). *Healthcare Business Continuity Planning Guide: Backup, ransomware & recovery*. Invenio IT.

<https://invenioit.com/continuity/healthcare-business-continuity-planning/>

Singh, G. (n.d.). *RPO, RTO, WRT and MTD: Essential Disaster Recovery Metrics for CISSP*. Learn Security Management.

<https://www.learnsecuritymanagement.com/cissp-rpo-rto-wrt-mtd-disaster-recovery-metrics>

Sullivan, E. (2025, July 7). *Types of backup explained: Incremental vs. Differential vs. full, etc.*: Techtarget. Search Data Backup.

<https://www.techtargget.com/searchdatabackup/feature/Full-incremental-or-differential-How-to-choose-the-correct-backup-type>